

EU AI Act

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. Overview and Significance

The European Union Artificial Intelligence Act (EU AI Act) entered into force on 1 August 2024, making it the world's first comprehensive binding legal framework for artificial intelligence. It applies to any provider that places an AI system on the EU market or puts one into service within the EU — regardless of where the provider is established. This extraterritorial reach means that US, UK, Asian, and global organisations selling AI-powered products or services in Europe are subject to the Act.

For CompTIA SecAI+ candidates, the EU AI Act is a primary compliance reference. It translates the OECD AI principles and the EU's ethical AI approach into enforceable legal obligations with substantial financial penalties for non-compliance. The Act also defines the first legally binding taxonomy of AI risk levels, giving security professionals a structured vocabulary for categorising AI risks that is rapidly being adopted beyond Europe as a global reference model.

2. Risk-Based Classification: The Four Risk Tiers

The EU AI Act organises AI systems into four risk tiers. The obligations imposed on a system depend on which tier it falls into. Understanding this taxonomy is essential for SecAI+ because exam scenarios frequently require you to classify a described AI system and identify the correct compliance obligations.

Risk Tier	Description	Examples	Obligations
Unacceptable Risk	Prohibited AI practices that pose an unacceptable threat to fundamental rights	Social scoring by governments; real-time biometric surveillance in public spaces; AI that exploits vulnerabilities of specific groups; subliminal manipulation	Banned outright — no deployment permitted under any circumstances
High Risk	AI systems in regulated sectors or used in high-stakes decisions that could harm health, safety, or fundamental rights	Medical devices, credit scoring, recruitment screening, critical infrastructure management, law enforcement, biometric identification	Conformity assessment; risk management system; data governance; technical documentation; human oversight; transparency; accuracy, robustness, and cybersecurity requirements
Limited Risk	AI systems that interact with humans or generate synthetic content, with transparency obligations	Chatbots, AI-generated content, deepfakes	Disclose AI nature to users; label synthetic content; maintain interaction logs
Minimal Risk	All other AI systems not classified above	Spam filters, AI in video games, most industrial AI	No mandatory obligations; voluntary codes of conduct encouraged

Exam anchor — High Risk classification: The High Risk tier is the most exam-tested category. Know that High Risk AI systems require a conformity assessment before deployment, a risk management system throughout the lifecycle, data governance controls, human oversight mechanisms, and cybersecurity requirements (Article 15).

3. Prohibited AI Practices (Unacceptable Risk)

Article 5 of the EU AI Act prohibits specific AI practices outright. These bans reflect cases where the EU determined that no legitimate use case can justify the risk to fundamental rights. Security professionals should memorise these prohibited practices because they appear as distractors and correct answers in exam scenarios:

- Social scoring by public authorities — using AI to evaluate individuals' social behaviour and deny them services or rights based on that score (as seen in certain government surveillance programmes).
- Subliminal manipulation — AI that exploits subconscious vulnerabilities to manipulate users into decisions they would not otherwise make.
- Exploitation of vulnerabilities — AI that targets people based on age, disability, or socioeconomic status to manipulate their behaviour.
- Real-time remote biometric identification in public spaces by law enforcement — with narrow exceptions for searching for missing children, preventing terrorist attacks, or identifying suspects in specified serious crimes.
- Biometric categorisation based on sensitive attributes — categorising individuals by race, political opinion, religion, or sexual orientation from biometric data.
- Emotion recognition in workplace and educational settings — AI that infers emotions from biometric data for decisions about employees or students.

4. High-Risk AI System Requirements

High-risk AI systems are subject to the most detailed compliance obligations in the Act. Providers of high-risk systems must satisfy six core requirements before placing them on the market and throughout their lifecycle:

- Risk Management System (Article 9) — establish and maintain a continuous risk management process covering identification, estimation, evaluation, and mitigation of reasonably foreseeable risks. Review after significant changes and upon evidence of incidents.
- Data and Data Governance (Article 10) — training, validation, and test datasets must be relevant, representative, free of errors, and complete for the intended purpose. Bias must be detected and corrected at the data level.
- Technical Documentation (Article 11) — maintain documentation sufficient for competent authorities to assess compliance. Update documentation when the system changes materially.

- Record Keeping / Logging (Article 12) — high-risk AI systems must automatically log events throughout operation to enable post-hoc auditing and investigation of incidents.
- Transparency and Information to Users (Article 13) — deployers must receive sufficient information about the AI system's capabilities, limitations, intended purpose, and interpretation of outputs.
- Human Oversight (Article 14) — high-risk AI systems must be designed to allow effective human oversight; where appropriate, a 'human in the loop' should be able to intervene, override, or stop the system.
- Accuracy, Robustness, and Cybersecurity (Article 15) — high-risk AI systems must achieve appropriate levels of accuracy for their intended purpose; be resilient to errors, faults, and inconsistencies; and be protected from adversarial attacks, data poisoning, model evasion, and exploitation of model vulnerabilities.

Article 15 — Cybersecurity is your domain: Article 15 explicitly lists adversarial attacks, model poisoning, and model evasion as cybersecurity threats that providers must mitigate. This is the article that gives security professionals direct mandate authority over high-risk AI system protection.

5. Conformity Assessment

Before a high-risk AI system can be deployed in the EU, the provider must complete a conformity assessment demonstrating that the system meets all applicable requirements. Most high-risk systems can self-certify via an internal conformity assessment, but systems in certain high-stakes domains (such as biometric identification or AI in critical infrastructure) require independent third-party audit by a Notified Body.

After conformity assessment, the provider affixes a CE marking and registers the system in the EU database of high-risk AI systems managed by the European AI Office. The database is publicly queryable, enabling deployers, regulators, and researchers to audit what high-risk AI systems are in use across the EU.

6. Obligations by Actor Role

The EU AI Act distinguishes between three types of actors, each with different obligations:

Actor	Definition	Key Obligations
Provider	Organisation that develops or places the AI system on the market under its own name or brand	Conformity assessment; CE marking; EU database registration; post-market monitoring; incident reporting to national authority
Deployer	Organisation that uses a high-risk AI system under its own authority for professional purposes	Follow provider instructions; implement human oversight; train staff; perform a fundamental rights impact assessment; report incidents involving harm
Importer / Distributor	Organisation that places a non-EU provider's AI system on the EU market	Verify provider compliance; affix CE marking where required; report non-compliance to national authority

Real-World Incident — Clearview AI and EU Data Regulators (2021-2024): Clearview AI's facial recognition system — which scraped billions of images from social media without consent — was banned by multiple EU data protection authorities (France, Italy, Greece, Sweden) and fined under GDPR. Under the EU AI Act, Clearview's system would fall into the Prohibited tier (biometric categorisation based on sensitive attributes and real-time biometric identification) and would be banned outright across the entire EU from day one. This case illustrates how the EU AI Act closes regulatory gaps that GDPR alone could not address.

7. General-Purpose AI (GPAI) Models

Title VIII of the EU AI Act addresses General-Purpose AI (GPAI) models — large foundation models (such as GPT-4, Claude, Gemini, Llama) that can perform a wide range of tasks and are integrated into downstream AI systems. The Act distinguishes between standard GPAI models and GPAI models with systemic risk (generally defined as models trained with compute exceeding 10^{25} FLOPs).

Standard GPAI providers must maintain technical documentation, comply with EU copyright law regarding training data, and publish a summary of training data. GPAI models with systemic risk face additional requirements: adversarial testing (red-teaming), incident reporting to the European AI Office, cybersecurity protections, and energy efficiency reporting. For security professionals, the GPAI provisions are particularly relevant when organisations are building applications on top of foundation model APIs — the deploying organisation inherits obligations that depend on what the GPAI provider has disclosed.

8. Penalties and Enforcement

The EU AI Act establishes a tiered penalty structure:

- Prohibited AI practices (Article 5 violations) — up to EUR 35 million or 7% of global annual turnover, whichever is higher.
- Violations of other obligations (e.g., High Risk requirements) — up to EUR 15 million or 3% of global annual turnover.
- Providing false or misleading information to notified bodies or national authorities — up to EUR 7.5 million or 1.5% of global annual turnover.
- SME caps — for small and medium-sized enterprises, penalties are capped at the lower of the percentage or the fixed amount thresholds.

Enforcement is managed by national competent authorities in each EU member state, coordinated by the newly established European AI Office. The AI Office has direct supervisory authority over GPAI model providers — a supranational enforcement capability that did not exist under prior EU AI legislation.

9. Implementation Timeline

Date	Milestone
1 August 2024	EU AI Act enters into force
2 February 2025	Prohibited AI practices (Article 5) apply — banned AI systems must be withdrawn

2 August 2025	GPAI model obligations apply; governance and penalties framework fully operational
2 August 2026	High-Risk AI system obligations fully apply (for new systems placed on market after August 2024)
2 August 2027	High-Risk AI systems already on market before August 2024 must comply

Security professionals supporting EU AI Act compliance programmes should note that high-risk system obligations have a phased application. Systems deployed before August 2024 have until 2027 to achieve compliance — but the prohibited practices ban applied from February 2025, so any system in that category required immediate action.

10. Common Exam Traps

- Trap 1 — The EU AI Act applies only to EU-based organisations: FALSE. It applies to any provider placing an AI system on the EU market, regardless of where they are established. A US company selling AI to EU customers must comply.
- Trap 2 — All AI chatbots are High Risk: FALSE. Chatbots fall in the Limited Risk tier unless they are used for high-stakes decisions (e.g., medical diagnosis support, legal advice). Their only mandatory obligation is to disclose that the user is interacting with an AI.
- Trap 3 — High-risk AI systems require third-party conformity assessment: FALSE. Most high-risk systems may self-certify via an internal conformity assessment. Only specific categories (biometric, critical infrastructure) require a Notified Body.
- Trap 4 — GPAI models above 10^{25} FLOPs are automatically prohibited: FALSE. They face additional obligations (red-teaming, incident reporting, cybersecurity) but are not prohibited. Prohibition applies only to the Article 5 categories.
- Trap 5 — Emotion recognition is always prohibited: FALSE. Emotion recognition is prohibited in workplace and educational settings. In other contexts (e.g., safety research), it may be permitted with appropriate safeguards.

Key Terms Glossary

Term	Definition
EU AI Act	The EU Artificial Intelligence Act (entered into force 1 August 2024) — the world's first comprehensive binding AI regulation, applying a risk-based classification to all AI systems placed on the EU market.
Unacceptable Risk	The highest EU AI Act risk tier — AI practices prohibited outright under Article 5 because they pose unacceptable threats to fundamental rights.
High Risk	EU AI Act tier for AI systems in regulated sectors or high-stakes decisions; subject to conformity assessment, data governance, logging, human oversight, and cybersecurity requirements.
Limited Risk	EU AI Act tier for AI systems with transparency obligations — must disclose AI nature to users and label synthetic content.
Conformity assessment	The process by which a provider demonstrates that a high-risk AI system

	meets EU AI Act requirements before placing it on the market; most systems may self-certify.
Notified Body	An independent third-party organisation accredited to conduct conformity assessments for specific high-risk AI categories (e.g., biometric systems).
CE marking	The mark affixed to an AI system after successful conformity assessment, indicating EU compliance; required before a high-risk system may be deployed in the EU.
GPAI model	General-Purpose AI model — a large foundation model (e.g., GPT-4, Llama) capable of performing diverse tasks; subject to specific obligations under EU AI Act Title VIII.
Systemic risk (GPAI)	GPAI models trained with more than 10^{25} FLOPs, subject to additional obligations including adversarial testing, cybersecurity controls, and incident reporting.
European AI Office	The EU body with direct supervisory authority over GPAI providers; coordinates national enforcement across member states.

Quick Revision Checklist

- Name the four EU AI Act risk tiers and give one example system for each.
- List the seven core requirements for High-Risk AI systems (Articles 9-15).
- State the six prohibited AI practices under Article 5.
- Explain the difference between Provider and Deployer obligations under the Act.
- Define GPAI model and state the threshold above which systemic risk obligations apply (10^{25} FLOPs).
- Know the penalty tiers: 7% / 3% / 1.5% of global turnover for the three violation categories.
- Recall the implementation timeline: prohibited practices from Feb 2025; GPAI from Aug 2025; high-risk systems from Aug 2026/2027.
- Explain why Article 15 (Accuracy, Robustness, and Cybersecurity) is directly relevant to security professionals.

10 Exam-Based MCQs — EU AI Act

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* LoanAI Ltd is a UK fintech company planning to offer its AI-powered credit-scoring system to EU banks. The system ingests applicant financial data and outputs a creditworthiness score used directly in loan approval decisions. The legal team asks the security architect to classify the system and identify the primary compliance obligation under the EU AI Act. Under the EU AI Act, which tier most accurately classifies this system and what is the PRIMARY compliance obligation?

- A) Minimal Risk — no mandatory obligations; voluntary code of conduct encouraged.
- B) Limited Risk — disclose AI nature to loan applicants.

- C) High Risk — complete conformity assessment and implement data governance, human oversight, and cybersecurity controls before deployment.
- D) Unacceptable Risk — the system must be withdrawn from the EU market immediately.

Answer: C **Explanation:** C is correct. A credit-scoring AI system is explicitly listed in Annex III of the EU AI Act as a High Risk system (AI used in creditworthiness assessment). High-risk systems require conformity assessment, data governance (Article 10), logging (Article 12), human oversight (Article 14), and cybersecurity (Article 15) before deployment. B is the obligation for chatbots (Limited Risk). A applies to spam filters and similar low-stakes systems. D applies to social scoring or biometric surveillance — credit scoring does not meet the prohibited criteria.

Q2. Scenario: *The security team at an EU-regulated medical imaging company is developing a risk treatment plan for a high-risk AI system (an AI-assisted radiology tool). The CISO wants to cite the specific EU AI Act article that mandates the adversarial testing programme she is proposing. Which Article of the EU AI Act MOST directly mandates that the AI security team implement adversarial attack defences for a high-risk AI system?*

- A) Article 9 — Risk Management System
- B) Article 13 — Transparency and Provision of Information
- C) Article 14 — Human Oversight
- D) Article 15 — Accuracy, Robustness, and Cybersecurity

Answer: D **Explanation:** D is correct. Article 15 explicitly requires high-risk AI systems to be protected against adversarial attacks, data poisoning, model evasion, and exploitation of model vulnerabilities — this is the cybersecurity mandate. Article 9 establishes the risk management system (which identifies the need for controls) but does not specify adversarial attack defences. Article 13 is about information to deployers. Article 14 is about human oversight mechanisms.

Q3. Scenario: *A European legal technology startup has deployed LegalBot, an AI chatbot that answers general legal questions for members of the public. The chatbot cannot file documents or represent clients — it only provides information. The compliance officer asks which EU AI Act obligations apply. Which action must LegalBot take to comply with the EU AI Act?*

- A) Complete a conformity assessment and register in the EU high-risk AI database.
- B) Disclose to users that they are interacting with an AI system and not a human lawyer.
- C) Implement human oversight mechanisms that allow a lawyer to override the AI's output.
- D) Obtain a CE marking from a Notified Body before deployment.

Answer: B **Explanation:** B is correct. A chatbot providing legal information falls in the Limited Risk tier — the only mandatory obligation is to disclose the AI nature of the system to users. A and C are High Risk obligations; a legal information chatbot that does not make legally binding decisions is not High Risk (though a chatbot that replaces a lawyer in formal proceedings might be). D (Notified Body CE marking) is required only for specific High Risk categories, not Limited Risk systems.

Q4. A US company provides an AI recruitment screening tool to EU-based employers. The tool ranks job applicants and feeds recommendations directly into hiring decisions. Under the EU AI Act, which statement is CORRECT?

- A) The US company is not subject to the EU AI Act because it is not established in the EU.
- B) The EU AI Act does not cover employment screening tools.
- C) The US company is a Provider subject to High Risk obligations because the tool is placed on the EU market.
- D) The tool is Minimal Risk because the final hiring decision is made by a human.

Answer: C **Explanation:** C is correct. The EU AI Act applies to any provider placing an AI system on the EU market, regardless of where the provider is established — the US location is irrelevant. Recruitment AI that feeds into hiring decisions is explicitly listed in Annex III as High Risk. A is false — the Act has extraterritorial reach. B is false — employment and recruitment AI is a named High Risk category. D is false — human involvement in the final step does not downgrade the AI system's risk classification.

Q5. A government agency in an EU member state deploys an AI system that generates a trust score for citizens based on their public social media activity and uses it to prioritise access to public services. Under the EU AI Act, how should this system be classified?

- A) High Risk — subject to conformity assessment and human oversight requirements.
- B) Limited Risk — must disclose AI nature to citizens.
- C) Unacceptable Risk — this is social scoring by a public authority and is prohibited under Article 5.
- D) Minimal Risk — no mandatory obligations.

Answer: C **Explanation:** C is correct. Social scoring by public authorities — using AI to evaluate citizens' social behaviour to prioritise access to public services — is one of the prohibited practices listed in Article 5 of the EU AI Act. This system must be withdrawn; no compliance pathway exists for prohibited systems.

Q6. Which of the following GPAI model obligations applies ONLY to models with systemic risk (trained with more than 10^{25} FLOPs)?

- A) Maintain technical documentation.
- B) Comply with EU copyright law regarding training data.
- C) Conduct adversarial testing (red-teaming) and report incidents to the European AI Office.
- D) Publish a summary of training data content.

Answer: C **Explanation:** C is correct. Adversarial testing and incident reporting to the European AI Office are obligations that apply exclusively to GPAI models with systemic risk (above 10^{25} FLOPs training compute). A, B, and D apply to all GPAI providers regardless of model size.

Q7. A high-risk AI system provider in Germany has completed its internal conformity assessment. What must it do NEXT to legally place the system on the EU market?

- A) Submit the conformity assessment to the European AI Office for review.
- B) Affix a CE marking and register the system in the EU high-risk AI database.

- C) Obtain certification from a Notified Body.
- D) Publish its technical documentation publicly on the EU AI Act compliance portal.

Answer: B **Explanation:** B is correct. After a successful internal conformity assessment, the provider affixes the CE marking and registers the system in the EU database of high-risk AI systems — these two steps are prerequisites for placing the system on the market. A is incorrect — the European AI Office does not review individual conformity assessments for most systems. C is incorrect for most high-risk systems — Notified Body assessment is required only for specific categories. D is incorrect — technical documentation is maintained but not publicly published.

Q8. A provider violates Article 5 of the EU AI Act by deploying a prohibited social scoring system. What is the MAXIMUM financial penalty the provider could face?

- A) EUR 7.5 million or 1.5% of global annual turnover.
- B) EUR 15 million or 3% of global annual turnover.
- C) EUR 35 million or 7% of global annual turnover.
- D) EUR 50 million or 10% of global annual turnover.

Answer: C **Explanation:** C is correct. Violations of the prohibited AI practices under Article 5 carry the highest penalty tier: up to EUR 35 million or 7% of global annual turnover, whichever is higher. B (EUR 15 million / 3%) applies to violations of other High Risk obligations. A (EUR 7.5 million / 1.5%) applies to providing false information to authorities. D does not exist in the EU AI Act.

Q9. Which statement about emotion recognition under the EU AI Act is CORRECT?

- A) Emotion recognition AI is prohibited in all contexts.
- B) Emotion recognition AI is prohibited in workplace and educational settings.
- C) Emotion recognition AI is classified as Limited Risk in all contexts.
- D) Emotion recognition AI is permitted without restriction if the user consents.

Answer: B **Explanation:** B is correct. The EU AI Act prohibits emotion recognition systems in workplace and educational settings under Article 5. In other contexts, emotion recognition may be permissible (subject to other applicable law such as GDPR) but is not a blanket prohibition. A is false — the prohibition is context-specific. C is false — context determines whether the system is prohibited, high-risk, or limited-risk. D is false — consent does not override Article 5 prohibitions.

Q10. A deployer using a third-party High Risk AI system for employee performance evaluation discovers that the system produces biased outputs for employees over 50. What is the deployer's PRIMARY obligation under the EU AI Act?

- A) The deployer has no obligations — all liability rests with the provider.
- B) Suspend use of the system, report the incident to the relevant national authority, and conduct a fundamental rights impact assessment.
- C) Immediately patch the AI model to remove the bias.
- D) Notify affected employees and publish a public statement on the organisation's website.

Answer: B **Explanation:** B is correct. Deployers of high-risk AI systems must report incidents involving harm or non-compliance to national authorities, suspend use where the system poses unacceptable risk, and are required to conduct fundamental rights impact assessments for HR applications. A is false — deployers have their own obligations independent of provider liability. C is incorrect — deployers do not modify provider models; remediation is the provider's responsibility. D is not a specific EU AI Act obligation for deployers (though GDPR breach notification may require it separately).